



UNIVERSIDAD MARIANO GÁLVEZ DE GUATEMALA

FACULTAD DE INGENIERÍA EN SISTEMAS DE INFORMACIÓN

MAESTRÍA EN SEGURIDAD INFORMÁTICA

TAREA 2 - MODELO DE AMENAZAS

Modelo de amenazas de ParaBank con OWASP Threat Dragon

Autor (es):

Gerbert David García Loaiza - ggarcial17@miumg.edu.gt

Carné: 1293-21-11608

Profesor

Ing. Mario Roberto López Sajquin

Curso

SEGURIDAD EN APLICACIONES - 42026-1293-013-E

Guatemala, octubre de 2026

Tabla de Contenido

Introducción	1
1. Alcance, fuentes y supuestos	2
2. Levantamiento de arquitectura	2
2.1 Inventario de componentes	2
2.2 Inventario de activos de información.....	3
2.3 Clasificación de flujos por criticidad	3
3. Diagramas de flujo de datos	4
3.1 Nivel 0: contexto.....	4
3.2 Nivel 1: procesos, almacenes y fronteras.....	4
3.3 Nivel 2: API de servicios y procesador de préstamos.....	5
3.4 Fronteras de confianza	6
4. Análisis de amenazas con STRIDE	6
4.1 Matriz STRIDE consolidada.....	6
4.2 Inventario de amenazas y descripción técnica	6
4.3 Registro de validación técnica	9
5. Priorización de riesgos	9
5.1 Matriz de riesgos.....	10
5.2 Top 10 de hallazgos prioritarios.....	10
5.3 Tratamiento del riesgo	10
6. Casos de abuso	10
6.1 Árbol de ataque	12
7. Controles de seguridad	12
8. Matriz de riesgos y remediación	14
9. Roadmap de mejoras	15
Conclusión	17
Referencias	18

Introducción

Este informe presenta el modelo de amenazas de ParaBank (la aplicación bancaria demo de Parasoft) desarrollado utilizando OWASP Threat Dragon, conforme a lo requerido en la Tarea 2 del curso. El análisis se adhiere a la lógica de la seguridad desde el diseño (shift-left): identificación de fallos potenciales antes de la producción, cuando la corrección cuesta menos.

Se elaboraron esquemas de flujo de datos de niveles 0, 1 y 2, se implementó la metodología STRIDE sobre cada elemento y se otorgó prioridad a los riesgos en función de su impacto y probabilidad. En total, se identificaron 23 amenazas: 5 de carácter crítico, 8 de grado alto, 9 de grado medio y 1 de grado bajo. Para las situaciones de críticas y altas, se registran casos de abuso, se implementan controles preventivos, se implementan medidas detectivas y correctivas, y se establece un plan de remediación a 12 meses.

ParaBank constituye una aplicación de carácter vulnerable, concebida para la realización de pruebas. Los descubrimientos se manifiestan como si se tratara de una institución bancaria auténtica para implementar el método; no constituyen una evaluación crítica de un producto productivo.

1. Alcance, fuentes y supuestos

Sistema evaluado. ParaBank, a través de sus módulos de banca digital, ofrece servicios de autenticación, creación de cuentas, transferencias, pago de facturas, préstamos, gestión, servicios SOAP/REST, bases de datos y mensajería. El módulo auxiliar denominado Bookstore se encuentra fuera del alcance debido a su no integración en el flujo bancario.

Fuente de la arquitectura. El código público del proyecto, publicado por Parasoft en 2026, el commit 13cc8d4c y su correspondiente archivo README. Durante el periodo laboral, la documentación en línea de Parasoft no se encontraba accesible, por lo que el análisis se fundamenta en el código fuente.

Criterio de evidencia. Cada amenaza señala si está corroborada en el código o si se trata de una hipótesis que requiere validación. Una hipótesis se refiere a un riesgo plausible que no pudo ser verificado mediante la lectura del código, como el control de propiedad de los recursos en la interfaz de programación de aplicaciones (API).

Supuestos de despliegue. Tomcat opera con la configuración preestablecida del README (HTTP, sin TLS finalizado en la aplicación), HyperSQL se encuentra en el puerto TCP 9001 y ActiveMQ se encuentra en TCP 61616. Si se emplea TLS o segmentación de red en el despliegue real, la probabilidad de varias amenazas disminuye.

Validación pendiente. La tarea solicita validar las amenazas con los equipos de Arquitectura y Desarrollo. En este contexto, únicamente se realizó un contraste con el código fuente; las hipótesis deben ser corroboradas mediante pruebas autorizadas en un entorno propio.

2. Levantamiento de arquitectura

2.1 Inventario de componentes

ParaBank es una aplicación desarrollada en Java e implementada en Apache Tomcat. La interfaz web se implementa mediante Spring MVC, mientras que los servicios SOAP y REST se publican utilizando Apache CXF. Ambos recurren a la misma lógica de negocio, cuyos datos se almacenan en HyperSQL y que utiliza ActiveMQ para el procesamiento de préstamos.

Tabla 1

Inventario de componentes de ParaBank

ID	Tipo	Componente	Función	Tecnología o archivo
P_web	Proceso	Interfaz web (Spring MVC + JSP)	Páginas *.htm; usa LoginInterceptor para las páginas protegidas	DispatcherServlet, parabank-servlet.xml
P_api	Proceso	Servicios SOAP/REST (Apache CXF)	Endpoints /services/* (JAX-WS y JAX-RS) y /services_proxy/*	CXFServlet, cxf.xml, ParaBankService
P_bl	Proceso	Lógica de negocio y DAO	BankManager, AdminManager y capa DAO JDBC	domain.logic, dao.jdbc
P_loan	Proceso	Procesador de préstamos	LoanProcessor con umbral configurable y listener JMS	AbstractLoanProcessor, JmsLoanProcessor
P_admin	Proceso	Administración y utilidades	admin.htm, db.htm, initializeDB.htm, jms.htm y operaciones de mantenimiento	AdminController, JmsListenerController
D_db	Almacén	Base de datos HyperSQL	Tablas Customer, Account, Transaction, Positions, Parameter, News	jdbc:hsqldb:hsqldb://localhost/parabank (9001)
D_mq	Almacén	Broker ActiveMQ	Colas de solicitud y respuesta de préstamos	applicationContext-jms.xml (61616)
D_log	Almacén	Bitácoras (log4j2)	Registros de la aplicación	log4j2.xml

ID	Tipo	Componente	Función	Tecnología o archivo
E_cli	Entidad externa	Cliente (navegador web)	Usuario final que opera su banca en línea desde un navegador	Navegador
E_adm	Entidad externa	Administrador / operador	Persona que configura la demo: parámetros, base de datos, JMS	Navegador
E_int	Entidad externa	Sistema integrador (cliente API)	Aplicación externa que consume los servicios SOAP/REST	HTTP SOAP/REST
E_prov	Entidad externa	Proveedor externo de préstamos	Sistema que aprueba o rechaza solicitudes de préstamo (WS/JMS)	ConfigurableLoanProvider

Nota. Elaboración propia con base en el código de ParaBank (Parasoft, 2026).

2.2 Inventario de activos de información

Tabla 2

Activos de información y su clasificación

Activo	Ubicación	Clasificación	Justificación
Credenciales (usuario y contraseña)	Tabla Customer, formularios y ruta de login	Crítico	Permiten tomar cuentas bancarias
SSN y datos personales	Tabla Customer	Crítico	Habilitan la suplantación de identidad
Saldos, cuentas y transacciones	Tablas Account y Transaction	Crítico	Integridad financiera
Sesión del cliente (JSESSIONID)	Cookie del navegador	Alto	Su robo equivale a suplantar al cliente
Parámetros de configuración	Tabla Parameter	Alto	Alteran reglas de negocio, como el umbral de préstamos
Solicitudes y respuestas de préstamo	Colas de ActiveMQ	Alto	Contienen decisiones crediticias
Bitácoras de la aplicación	log4j2	Medio	Evidencia para auditoría
Noticias y contenido público	Tabla News	Bajo	Información pública

Nota. Elaboración propia.

2.3 Clasificación de flujos por criticidad

La Tabla 3 categoriza los flujos de información y documenta las características de confidencialidad e integridad establecidas en Threat Dragon. Los flujos que emplean HTTP, JDBC o JMS sobre TCP se identificaron sin cifrado debido a su representación del despliegue por defecto; de esta manera, el motor de reglas no oculta amenazas reales. Se identificaron como protegidos los flujos internos dentro de la misma JVM.

Tabla 3

Flujos de datos, propiedades y criticidad

Flujo	Origen → Destino	Protocolo	Conf./Integ.	Frontera	Criticidad
F01	Cliente (navegador web) → Interfaz web (Spring MVC + JSP)	HTTP	No	TB1	Crítico
F02	Interfaz web (Spring MVC + JSP) → Cliente (navegador web)	HTTP	No	TB1	Alto
F03	Sistema integrador (cliente API) → Servicios SOAP/REST (Apache CXF)	HTTP	No	TB1	Crítico
F04	Interfaz web (Spring MVC + JSP) → Lógica de negocio y DAO	In-process	Sí	-	Medio
F05	Servicios SOAP/REST (Apache CXF) → Lógica de negocio y DAO	In-process	Sí	-	Medio
F06	Lógica de negocio y DAO → Base de datos HyperSQL	JDBC/TCP 9001	No	TB2	Crítico
F07	Lógica de negocio y DAO → Procesador de préstamos	In-process	Sí	-	Medio
F08	Procesador de préstamos → Broker ActiveMQ	JMS/TCP 61616	No	TB2	Alto

Flujo	Origen → Destino	Protocolo	Conf./Integ	Frontera	Criticidad
F09	Procesador de préstamos → Proveedor externo de préstamos	WS/JMS	No	TB3	Alto
F10	Administrador / operador → Administración y utilidades	HTTP	No	TB1	Crítico
F11	Administración y utilidades → Base de datos HyperSQL	JDBC/TCP 9001	No	TB2	Crítico
F12	Lógica de negocio y DAO → Bitácoras (log4j2)	Archivo	Sí	-	Medio
F13	Administración y utilidades → Procesador de préstamos	In-process	Sí	-	Alto

Nota. Conf./Integ. indica si el flujo provee confidencialidad e integridad. Elaboración propia con base en el modelo de Threat Dragon.

3. Diagramas de flujo de datos

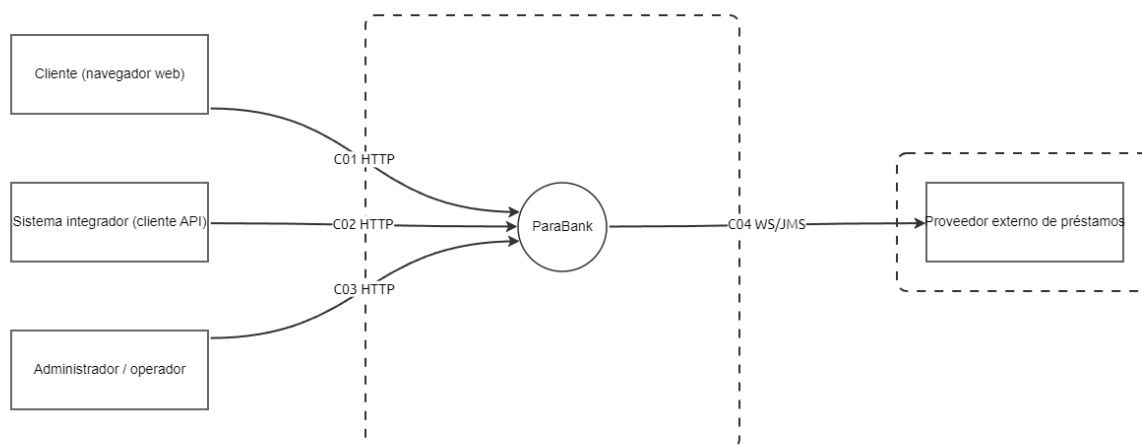
Los diagramas fueron confeccionados utilizando el software OWASP Threat Dragon. El Nivel 0 proporciona una representación del contexto del sistema, el Nivel 1 desglosa los procesos, almacenes y flujos principales con sus respectivas fronteras de confianza, mientras que el Nivel 2 especifica el servicio de API y el circuito de préstamos, que se refiere a la integración con terceros y middleware.

3.1 Nivel 0: contexto

ParaBank está en interacción con cuatro entidades externas: el cliente, el administrador, el sistema integrador que consume las interfaces de programación de aplicaciones (APIs) y el proveedor externo de préstamos. La frontera TB1 distingue la aplicación de Internet, mientras que la frontera TB3 distingue la aplicación del proveedor externo.

Figura 1

DFD Nivel 0: contexto de ParaBank



Nota. Elaboración propia con OWASP Threat Dragon.

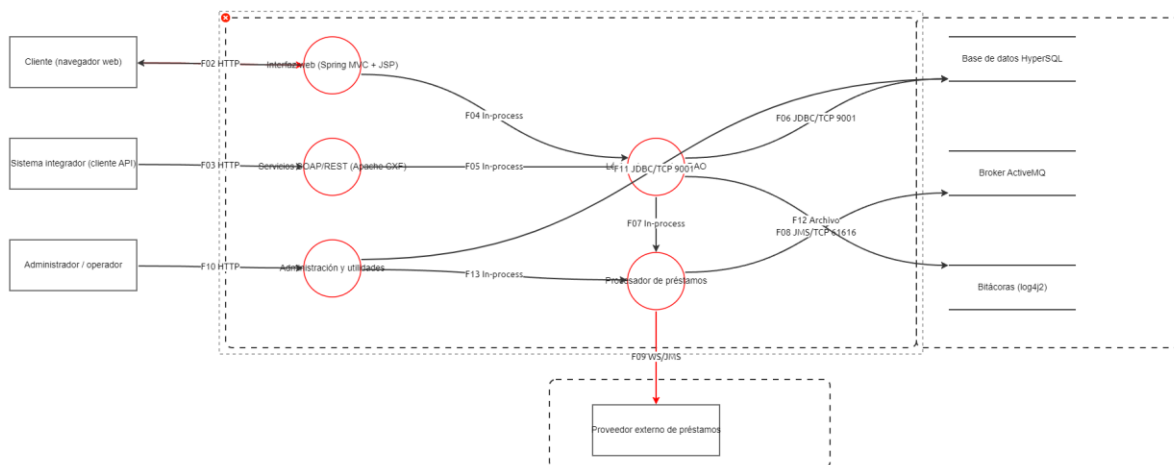
3.2 Nivel 1: procesos, almacenes y fronteras

El Nivel 1 distingue la interfaz web, los servicios SOAP/REST, la lógica empresarial, el procesador de préstamos y la gestión. Las unidades de almacenamiento comprenden la base de datos HyperSQL, el intermediario ActiveMQ y las bitácoras. Los procesos y los almacenes fueron

modelados de manera independiente para prevenir la confusión de las reglas de STRIDE entre ambos.

Figura 2

DFD Nivel 1: procesos, almacenes y fronteras de confianza



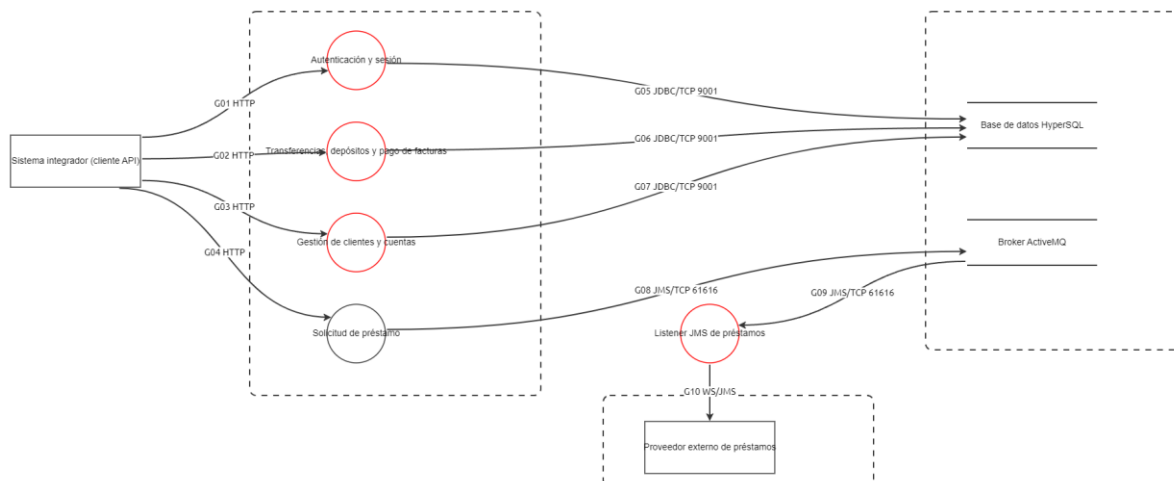
Nota. Los elementos con borde rojo tienen amenazas asociadas. Elaboración propia con OWASP Threat Dragon.

3.3 Nivel 2: API de servicios y procesador de préstamos

Este nivel desglosa el servicio de API en aspectos como la autenticación, las transferencias y pagos, la administración de clientes y la solicitud de préstamo, y expone el proceso de transmisión de mensajes a través de la cola JMS hasta el proveedor externo.

Figura 3

DFD Nivel 2: API de servicios y procesador de préstamos



Nota. Elaboración propia con OWASP Threat Dragon.

3.4 Fronteras de confianza

Tabla 4

Fronteras de confianza identificadas

Frontera	Separa	Flujos que la cruzan	Motivo
TB1	Internet y redes no confiables Aplicación en Tomcat	F01, F02, F03, F10	Es donde entra todo dato no confiable
TB2	Aplicación Base de datos y broker	F06, F08, F11	Los datos de mayor valor están al otro lado
TB3	Aplicación Proveedores externos de préstamos	F09	Es un tercero fuera del control del equipo

Nota. Elaboración propia.

4. Análisis de amenazas con STRIDE

Se implementó la metodología STRIDE a cada flujo, proceso y almacén representado en el diagrama. Las 23 amenazas fueron identificadas manualmente, respaldadas por el código fuente; no se originan a partir del motor automático de Threat Dragon. Además, se aconseja implementar la generación automática de la herramienta, cotejar ambas listas y documentar las discrepancias detectadas.

4.1 Matriz STRIDE consolidada

Tabla 5

Cantidad de amenazas por elemento y categoría STRIDE

Elemento	S	T	R	I	D	E	Total
Gestión de clientes y cuentas		1					1
Autenticación y sesión	1			1			2
Administración y utilidades			1			1	2
Servicios SOAP/REST (Apache CXF)				2	1	2	5
Base de datos HyperSQL	1			1			2
Broker ActiveMQ		1					1
Flujo F01				1			1
Interfaz web (Spring MVC + JSP)	1	1					2
Transferencias, depósitos y pago de facturas		1					1
Procesador de préstamos		1					1
Lógica de negocio y DAO			1			1	2
Bitácoras (log4j2)		1					1
Listener JMS de préstamos					1		1
Flujo F09	1						1
Total	4	6	2	5	2	4	23

Nota. S = Spoofing, T = Tampering, R = Repudiation, I = Information Disclosure, D = Denial of Service, E = Elevation of Privilege.

4.2 Inventario de amenazas y descripción técnica

La Tabla 6 detalla cada amenaza, indicando el flujo de información, la frontera de confianza que se traspasa y el impacto concreto sobre el componente afectado. La columna final diferencia lo que ha sido confirmado en el código de lo que constituye una hipótesis a verificar.

Tabla 6
Amenazas identificadas con STRIDE

ID	Amenaza	STRIDE	Elemento	Descripción técnica y evidencia
T01	Inyección SQL en la actualización de clientes	Tampering	Gestión de clientes y cuentas	El DAO arma el UPDATE concatenando customer.getFirstName() dentro de la sentencia; el dato cruza TB1 por POST /customers/update/{id} y llega sin parametrizar al motor HyperSQL (F06/G07). Un atacante puede cerrar la cadena e inyectar SQL que altere o exponga filas de Customer. Evidencia: Confirmado en código (JdbcCustomerDao.updateCustomer; el propio comentario indica que el fallo es intencional). Existe SecureJdbcCustomerDao con parámetros
T02	Credenciales viajan en la URL (GET /login/{usuario}/{contraseña})	Information Disclosure	Autenticación y sesión	El servicio REST recibe usuario y contraseña como segmentos de la ruta. Al cruzar TB1 quedan en el historial del navegador, en logs de Tomcat, proxies y cabeceras Referer, aun si el canal fuera cifrado. Evidencia: Confirmado en código (@Path("/login/{username}/{password}") en ParaBankService)
T03	Páginas de administración fuera del control de sesión	Elevation of Privilege	Administración y utilidades	El mapeo protegido por LoginInterceptor solo cubre nueve páginas de cliente; admin.htm, db.htm, initializeDB.htm y jms.htm no figuran, por lo que cualquiera que llegue a Tomcat podría cambiar parámetros, reiniciar la BD o detener el listener JMS (F10, F11, F13). Evidencia: Confirmado en parabank-servlet.xml (secureHandlerMapping). A validar: que no exista otro filtro o regla de red
T04	Endpoints de mantenimiento expuestos en la API (cleanDB, initializeDB, setParameter, shutdownJmsListener)	Elevation of Privilege	Servicios SOAP/REST (Apache CXF)	La interfaz de servicio publica operaciones destructivas y de configuración sin mecanismo de autenticación visible en la propia interfaz. Un cliente API externo que cruza TB1 puede borrar datos, reinicializar la BD o apagar la mensajería (F03, F05). Evidencia: Confirmado la exposición de rutas en ParaBankService. A validar: ausencia de control de acceso en la implementación
T05	Acceso a cuentas y clientes ajenos mediante identificadores (BOLA/IDOR)	Information Disclosure	Servicios SOAP/REST (Apache CXF)	Rutas como /accounts/{accountId}, /customers/{customerId} y /transactions/{id} reciben identificadores secuenciales; la interfaz no muestra verificación de que el recurso pertenezca al llamante. Un atacante autenticado o anónimo puede enumerar identificadores y leer datos personales y financieros (F03, F05). Evidencia: Hipótesis a validar con pruebas autorizadas: la interfaz no muestra control de propiedad del recurso
T06	Contraseñas y SSN almacenados sin protección criptográfica	Information Disclosure	Base de datos HyperSQL	La tabla Customer guarda password y ssn y el login compara el valor directamente en SQL (username = ? AND password = ?), lo que implica almacenamiento en texto claro. Una lectura de la BD (por ejemplo vía T01 o por el puerto 9001) expone credenciales y datos de identidad (F06). Evidencia: Confirmado en código (JdbcCustomerDao: BASE_QUERY_SQL y consulta de login)
T07	Cuenta sa sin contraseña y puerto HyperSQL 9001 accesible	Spoofing	Base de datos HyperSQL	jdbc.properties define jdbc.username=sa con contraseña vacía y el servidor HyperSQL escucha por TCP (9001). Cualquier host con alcance de red puede conectarse como administrador de la BD y saltar toda la lógica de la aplicación (F06, F11). Evidencia: Confirmado en jdbc.properties y README (puerto 9001)
T08	Broker ActiveMQ en 0.0.0.0:61616 sin autenticación configurada	Tampering	Broker ActiveMQ	El broker se publica en todas las interfaces y la configuración no declara plugin de autenticación ni autorización. Un tercero puede inyectar o leer mensajes de solicitud y respuesta de préstamos que cruzan TB2 (F08). Evidencia: Confirmado en applicationContext-jms.xml (transportConnector tcp://0.0.0.0:61616; sin plugin de seguridad en ese bloque)
T09	Tráfico HTTP sin TLS: credenciales y cookie de sesión interceptables	Information Disclosure	Flujo F01	El despliegue por defecto en Tomcat usa HTTP. Los flujos F01, F02, F03 y F10 cruzan la frontera de Internet con Provides Confidentiality = No e Integrity = No, de modo que un atacante en la ruta puede leer credenciales y cookie JSESSIONID o modificar montos. Evidencia: Supuesto de despliegue por defecto; depende de la instalación
T10	CSRF sobre transferencias y pagos	Tampering	Interfaz web (Spring MVC + JSP)	No se encontraron referencias a token anti-CSRF en el código. Una página maliciosa puede hacer que el navegador de la víctima, con sesión activa, envíe un POST a transfer.htm o billpay.htm sin su consentimiento (F01). Evidencia: Hipótesis: búsqueda de 'csrf' sin resultados en el código fuente analizado

ID	Amenaza	STRIDE	Elemento	Descripción técnica y evidencia
T11	Manipulación de monto o cuenta en operaciones monetarias	Tampering	Transferencias, depósitos y pago de facturas	Monto, cuenta origen y destino llegan como parámetros del cliente a /transfer, /deposit, /withdraw y /billpay (G02). Sin validación de negocio en el servidor ni integridad del canal, un atacante puede modificar el monto o ejecutar operaciones en nombre de otro. Evidencia: Hipótesis a validar: depende de las validaciones de la implementación del servicio
T12	Fuerza bruta y credential stuffing sobre el login	Spoofing	Autenticación y sesión	No se observa limitación de intentos ni bloqueo de cuenta; el login por ruta facilita el scripting masivo (G01, G05). Un atacante con listas de credenciales filtradas puede suplantar clientes legítimos. Evidencia: Hipótesis: no se identificó rate limiting ni bloqueo en el código revisado
T13	Alteración del umbral de aprobación de préstamos y del modo de acceso	Tampering	Procesador de préstamos	loanProcessorThreshold y accessmode se leen de la tabla Parameter y pueden modificarse con setParameter o admin.htm. Combinado con las amenazas de acceso administrativo, un atacante puede forzar aprobaciones fraudulentas de préstamos (F13). Evidencia: Confirmado el uso del parámetro en AbstractLoanProcessor; la explotación depende de T03 y T04
T14	Cabeceras CORS abiertas a cualquier origen	Information Disclosure	Servicios SOAP/REST (Apache CXF)	ParaBankService está anotado con @CrossOriginResourceSharing(allowAllOrigins = true). Cualquier sitio web puede invocar la API desde el navegador de un usuario autenticado y leer la respuesta (F03). Evidencia: Confirmado en código (ParaBankService)
T15	Falta de no repudio en transacciones	Repudiation	Lógica de negocio y DAO	Las transacciones no llevan firma ni sello de tiempo verificable del cliente; si este niega una operación, el banco solo cuenta con su propio registro (F04, F12). Evidencia: Hipótesis: no se hallaron firmas ni confirmación fuerte de operaciones
T16	Acciones administrativas sin identidad ni auditoría	Repudiation	Administración y utilidades	Como el módulo administrativo no exige autenticación, los cambios de parámetros, reinicios de BD y paradas de JMS no pueden atribuirse a una persona (F10, F11, F13). Evidencia: Consecuencia de T03; a validar
T17	Bitácoras modificables y con datos sensibles	Tampering	Bitácoras (log4j2)	Los logs de log4j2 se escriben en archivo local sin protección de integridad; un atacante con acceso al host puede borrar rastros, y los registros pueden contener identificadores de clientes (F12). Evidencia: Hipótesis: configuración de log4j2 por defecto
T18	Denegación de servicio por API sin límites	Denial of Service	Servicios SOAP/REST (Apache CXF)	Sin rate limiting ni cuotas, un cliente puede saturar Tomcat o la BD con peticiones masivas (F03, F05, F06). Evidencia: Hipótesis: no se identificó limitación de tasa
T19	Inundación de solicitudes de préstamo sobre la cola JMS	Denial of Service	Listener JMS de préstamos	El listener usa 5 consumidores concurrentes y el broker no es persistente; una avalancha de solicitudes puede saturar la cola o perder mensajes legítimos (G08, G09). Evidencia: Confirmado en applicationContext-jms.xml (concurrentConsumers=5; persistent=false)
T20	Suplantación del proveedor de préstamos o respuesta falsa	Spoofing	Flujo F09	La respuesta del proveedor cruza TB3 por WS/JMS; sin autenticación mutua ni firma, un tercero puede responder aprobaciones falsas. Evidencia: Hipótesis: depende de la configuración del proveedor
T21	Procesamiento XML inseguro en servicios SOAP (XXE)	Elevation of Privilege	Servicios SOAP/REST (Apache CXF)	Los endpoints SOAP procesan XML con JAXB/CXF; si el parser permite entidades externas, un mensaje manipulado puede leer archivos del servidor o provocar SSRF (F03). Evidencia: Hipótesis a validar con revisión de la configuración del parser
T22	Dependencias de terceros sin gestión de vulnerabilidades	Elevation of Privilege	Lógica de negocio y DAO	La aplicación depende de Spring, CXF, WSS4J, ActiveMQ y Tomcat. Una vulnerabilidad conocida en cualquiera permite ejecución remota o escalamiento sin tocar el código propio. Evidencia: Riesgo general de cadena de suministro; verificable con SCA sobre pom.xml
T23	Cookie de sesión sin atributos de endurecimiento verificados	Spoofing	Interfaz web (Spring MVC + JSP)	No se verificó que JSESSIONID use Secure, HttpOnly y SameSite ni que exista timeout por inactividad; una sesión robada permite suplantar al cliente (F02). Evidencia: Hipótesis a validar en web.xml y en la configuración de Tomcat

Nota. Elaboración propia con base en el código de ParaBank (Parasoft, 2026).

4.3 Registro de validación técnica

Tabla 7

Verificaciones realizadas contra el código fuente

Verificación	Resultado
Rutas protegidas por LoginInterceptor	Solo nueve páginas de cliente en secureHandlerMapping; no incluye admin, db, initializeDB ni jms (T03)
Acceso a datos	El UPDATE de Customer concatena firstName (T01); el resto de los DAO usa parámetros
Credenciales de la base de datos	jdbc.username=sa con contraseña vacía (T07)
Broker de mensajería	tcp://0.0.0.0:61616 sin plugin de seguridad en ese bloque (T08)
CORS	@CrossOriginResourceSharing(allowAllOrigins = true) (T14)
Token anti-CSRF	La búsqueda de «csrf» en el código no arrojó resultados (T10)
Validación con Arquitectura y Desarrollo	Pendiente: las hipótesis requieren pruebas autorizadas

Nota. Elaboración propia.

Figura 4

Amenazas del elemento «Interfaz web» en el reporte de Threat Dragon

Interfaz web (Spring MVC + JSP) (Proceso)

Descripción: Páginas *.htm; usa LoginInterceptor para las páginas protegidas. (DispatcherServlet, parabank-servlet.xml)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
10	CSRF sobre transferencias y pagos	Tampering	Alta	Abierto		No se encontraron referencias a token anti-CSRF en el código. Una página maliciosa puede hacer que el navegador de la víctima, con sesión activa, envíe un POST a transfer.htm o billpay.htm sin su consentimiento (F01). Riesgo: impacto Alto, probabilidad Media = Alto. Evidencia: Hipótesis: búsqueda de 'csrf' sin resultados en el código fuente analizado.	[Aplicación] Token anti-CSRF por sesión en formularios de escritura; [Aplicación] Cookie SameSite=Lax/Strict; [Aplicación] Reautenticación o OTP para transferencias; [Monitoreo] Alerta de transferencias atípicas
23	Cookie de sesión sin atributos de endurecimiento verificados	Spoofing	Media	Abierto		No se verificó que JSESSIONID use Secure, HttpOnly y SameSite ni que exista timeout por inactividad; una sesión robada permite suplantar al cliente (F02). Riesgo: impacto Medio, probabilidad Media = Medio. Evidencia: Hipótesis a validar en web.xml y en la configuración de Tomcat.	[Aplicación] Cookie Secure/HttpOnly/SameSite, regeneración del ID al autenticar y timeout de 15 minutos; [Monitoreo] Detección de sesiones simultáneas desde orígenes distintos

Nota. Fragmento del reporte PDF generado por OWASP Threat Dragon. Muestra las amenazas T10 y T23 con su tipo, prioridad, estado y mitigaciones. La herramienta solo maneja las prioridades Alta, Media y Baja, por lo que las amenazas de riesgo Crítico aparecen como Alta.

5. Priorización de riesgos

El impacto se evalúa en términos de Crítico (4), Alto (3), Medio (2) o Bajo (1), mientras que la probabilidad se clasifica en Muy Alta (4), Alta (3), Media (2) o Baja (1). El riesgo es el resultado de ambos factores: Crítico si la puntuación es de 9 o más, Alto si es de 6 a 8, Medio si es de 3 a 5 y Bajo si es de 1 a 2. Esta norma replica la tabla del enunciado correspondiente a la tarea (Alto con Alto es Crítico, Medio con Medio es Medio y Bajo con Bajo es Bajo).

5.1 Matriz de riesgos

Tabla 8

Matriz de riesgos por impacto y probabilidad

Impacto \ Probabilidad	Muy Alta	Alta	Media	Baja
Crítico	Crítico	Crítico T03, T04	Alto T06, T07	Medio
Alto	Crítico T01	Crítico T02, T05	Alto T08, T09, T10, T11, T12, T13	Medio T20, T21, T22
Medio	Alto	Alto	Medio T14, T15, T16, T18, T19, T23	Bajo T17
Bajo	Medio	Medio	Bajo	Bajo

Nota. Cada celda indica el nivel de riesgo y las amenazas que le corresponden. Elaboración propia.

5.2 Top 10 de hallazgos prioritarios

Tabla 9

Diez amenazas de mayor riesgo

#	ID	Hallazgo	Impacto	Probabilidad	Nivel
1	T01	Inyección SQL en la actualización de clientes	Alto	Muy Alta	Crítico
2	T03	Páginas de administración fuera del control de sesión	Crítico	Alta	Crítico
3	T04	Endpoints de mantenimiento expuestos en la API (cleanDB, initializeDB, setParameter, shutdownJmsListener)	Crítico	Alta	Crítico
4	T02	Credenciales viajan en la URL (GET /login/{usuario}/{contraseña})	Alto	Alta	Crítico
5	T05	Acceso a cuentas y clientes ajenos mediante identificadores (BOLA/IDOR)	Alto	Alta	Crítico
6	T06	Contraseñas y SSN almacenados sin protección criptográfica	Crítico	Media	Alto
7	T07	Cuenta sa sin contraseña y puerto HyperSQL 9001 accesible	Crítico	Media	Alto
8	T08	Broker ActiveMQ en 0.0.0.0:61616 sin autenticación configurada	Alto	Media	Alto
9	T09	Tráfico HTTP sin TLS: credenciales y cookie de sesión interceptables	Alto	Media	Alto
10	T10	CSRF sobre transferencias y pagos	Alto	Media	Alto

Nota. El ranking completo de las 23 amenazas se presenta en la Tabla 12. Elaboración propia.

5.3 Tratamiento del riesgo

Conforme a las estrategias discutidas en el aula, se plantea la mitigación de todas las amenazas críticas y elevadas, la transferencia de una porción del riesgo de interrupción del servicio a través de protección anti-DDoS o un servicio administrado, la aceptación formal de la amenaza de nivel Bajo (T17) con revisión periódica, y la evitación de la divulgación de las operaciones de mantenimiento en producción.

6. Casos de abuso

Para cada amenaza crítica o elevada, se registró el objetivo del atacante, el vector, las precondiciones, el método de explotación, el impacto y los controles preventivos, detectivos y correctivos propuestos.

Tabla 10*Catálogo de casos de abuso para amenazas críticas y altas*

ID	Actor y objetivo	Vector, precondition y método	Impacto	Controles
T01 Crítico	Atacante externo con acceso a la API. Objetivo: Leer o modificar datos de todos los clientes.	Vector: POST /customers/update/{id} con firstName malicioso. Precondición: Alcance de red al servicio y un ID de cliente válido. Método: Cerrar la cadena con una comilla y concatenar sentencias o subconsultas sobre la tabla Customer.	Pérdida de integridad y confidencialidad de la base de clientes	Preventivo: Consultas parametrizadas, validación de entrada, BD con mínimo privilegio. Detectivo: WAF y SIEM con reglas de inyección, alerta de errores SQL. Correctivo: Revocar credenciales, restaurar desde respaldo, corregir el DAO y notificar el incidente.
T02 Crítico	Atacante en la red o con acceso a logs. Objetivo: Obtener credenciales de clientes.	Vector: Lectura de logs de Tomcat, proxies o historial con la URL de login. Precondición: Acceso a logs o al tráfico. Método: Extraer usuario y contraseña de la ruta /login/{usuario}/{contraseña}.	Toma de cuentas bancarias	Preventivo: Login por POST con token y TLS. Detectivo: DLP sobre logs, alerta de accesos desde ubicaciones nuevas. Correctivo: Forzar cambio de contraseñas expuestas y depurar logs.
T03 Crítico	Atacante externo anónimo. Objetivo: Tomar control administrativo de la aplicación.	Vector: Navegar a /parabank/admin.htm, db.htm o jms.htm. Precondición: Alcance HTTP al servidor. Método: Cambiar parámetros, reinicializar la BD o apagar el listener JMS desde las páginas administrativas.	Pérdida de datos, fraude por parámetros alterados y caída del servicio	Preventivo: Rol ADMIN con MFA y acceso solo desde red de gestión. Detectivo: Alerta por acceso a rutas administrativas. Correctivo: Restaurar parámetros y BD, rotar credenciales y cerrar la exposición.
T04 Crítico	Cliente API malicioso. Objetivo: Destruir datos o dejar fuera de servicio el sistema.	Vector: POST /services/bank/cleanDB, /initializeDB, /shutdownJmsListener. Precondición: Alcance a /services. Método: Invocar directamente las operaciones de mantenimiento.	Pérdida total de datos y disponibilidad	Preventivo: Retirar o proteger con OAuth 2.0 y scope administrativo. Detectivo: Registro y alerta de invocaciones de mantenimiento. Correctivo: Restauración desde respaldo y revisión del gateway.
T05 Crítico	Cliente autenticado malicioso o anónimo. Objetivo: Leer datos financieros y personales ajenos.	Vector: GET /accounts/{id} y /customers/{id} con IDs secuenciales. Precondición: Conocer o adivinar el formato del ID. Método: Enumeración de identificadores.	Exposición de PII y saldos de múltiples clientes	Preventivo: Autorización a nivel de objeto e IDs no predecibles. Detectivo: Alerta por barridos secuenciales de IDs. Correctivo: Invalidar sesiones, notificar y corregir las comprobaciones.
T06 Alto	Atacante con acceso a datos. Objetivo: Usar credenciales y SSN en claro.	Vector: Lectura de la tabla Customer (inyección SQL o acceso directo a la BD). Precondición: Cualquier acceso de lectura a la BD. Método: SELECT de usernames, passwords y SSN.	Robo masivo de identidades y reutilización de contraseñas	Preventivo: Hash Argon2id y cifrado de SSN. Detectivo: Alerta por consultas masivas sobre Customer. Correctivo: Rotación forzada de credenciales y notificación a clientes.
T07 Alto	Atacante con alcance de red a la BD. Objetivo: Controlar la base de datos.	Vector: Conexión JDBC/TCP al puerto 9001 como sa sin contraseña. Precondición: Alcance de red al puerto. Método: Conectar con un cliente JDBC y ejecutar SQL libre.	Lectura, modificación y destrucción total de datos	Preventivo: Cuenta de servicio de mínimo privilegio, bóveda de secretos y segmentación. Detectivo: Logging de conexiones y alertas por orígenes nuevos. Correctivo: Rotar credenciales y reconstruir desde respaldo.
T08 Alto	Atacante con alcance de red al broker. Objetivo: Falsificar o leer solicitudes de préstamo.	Vector: Conexión a tcp://host:61616. Precondición: Alcance al puerto del broker. Método: Publicar mensajes de respuesta con aprobación o consumir solicitudes.	Préstamos fraudulentos y fuga de datos	Preventivo: Autenticación, ACL, TLS y enlace a red interna. Detectivo: Alertas de conexiones y mensajes anómalos. Correctivo: Purgar colas, rotar credenciales y revisar préstamos aprobados.

ID	Actor y objetivo	Vector, precondition y método	Impacto	Controles
T09 Alto	Atacante en la ruta de red (MITM). Objetivo: Capturar credenciales y sesiones.	Vector: Intercepción del tráfico HTTP del cliente. Precondición: Posición de red intermedia (Wi-Fi público, proxy). Método: Sniffing de F01/F02 para obtener contraseña o JSESSIONID.	Suplantación y fraude con la cuenta de la víctima	Preventivo: TLS 1.2+, HSTS y cookies Secure. Detectivo: Monitoreo de sesiones simultáneas. Correctivo: Invalidar sesiones y forzar cambio de contraseña.
T10 Alto	Atacante externo. Objetivo: Transferir fondos desde cuentas de víctimas.	Vector: Página maliciosa que dispara POST a transfer.htm. Precondición: La víctima tiene sesión activa. Método: Formulario auto-enviado o petición cruzada de sitio.	Transferencias no autorizadas	Preventivo: Token CSRF, SameSite y OTP en operaciones de valor. Detectivo: Reglas antifraude por monto y beneficiario nuevo. Correctivo: Reversar transferencias y reforzar controles.
T11 Alto	Cliente malicioso. Objetivo: Alterar monto o cuenta de una operación.	Vector: Modificar parámetros en POST /transfer o /billpay. Precondición: Sesión válida o acceso al API. Método: Cambiar amount o cuenta origen en la petición.	Fraude financiero y descuadre contable	Preventivo: Validación de negocio en servidor, firma e idempotencia. Detectivo: Conciliación y reglas antifraude. Correctivo: Reversión y ajuste contable.
T12 Alto	Atacante con listas de credenciales filtradas. Objetivo: Tomar cuentas de clientes.	Vector: Peticiones automatizadas a /login. Precondición: Listas de usuarios y contraseñas. Método: Credential stuffing sin límite de intentos.	Fraude y daño reputacional	Preventivo: MFA, bloqueo progresivo y rate limiting. Detectivo: SIEM con alerta de fallos repetidos. Correctivo: Bloquear cuentas, forzar restablecimiento y notificar.
T13 Alto	Atacante con acceso administrativo (por T03/T04). Objetivo: Aprobar préstamos fraudulentos.	Vector: Modificar loanProcessorThreshold vía setParameter o admin.htm. Precondición: Acceso a la administración. Método: Subir el umbral para que toda solicitud sea aprobada.	Pérdidas por préstamos otorgados indebidamente	Preventivo: Doble aprobación y rangos válidos. Detectivo: Alerta de cambios de parámetros. Correctivo: Revertir parámetros y auditar préstamos aprobados.

Nota. Elaboración propia.

6.1 Árbol de ataque

El propósito de visualizar o modificar la información de los clientes puede lograrse mediante tres vías: a través de la aplicación (introduciendo SQL en T01, enumerando identificadores en T05 y exponiendo credenciales en la URL en T02), a través de la infraestructura (conectando directamente como sa en T07 y accediendo a páginas de administración sin autenticación en T03) y mediante la mensajería (remitiendo mensajes al broker abierto en T08). La existencia de múltiples trayectorias hacia un objetivo común explica por qué la mitigación debe abarcar todas las capas.

7. Controles de seguridad

Cada amenaza fue vinculada a controles de aplicación, interfaz de programación de aplicaciones (API), infraestructura y monitoreo. La columna final contrasta el riesgo inicial con el riesgo residual proyectado tras su aplicación; estos son valores que deben ser validados con el equipo, no constituyen una garantía.

Tabla 11

Controles por amenaza y riesgo residual

ID	Amenaza	Controles	Riesgo inicial → residual
T01	Inyección SQL en la actualización de clientes	Aplicación: Sentencias parametrizadas y uso de SecureJdbcCustomerDao en toda ruta de escritura API: Validación de esquema y longitud de campos en el endpoint Infraestructura: Cuenta de BD con privilegios mínimos distinta de sa Monitoreo: Alerta de WAF/SIEM por patrones de inyección	Crítico → Bajo

ID	Amenaza	Controles	Riesgo inicial → residual
T02	Credenciales viajan en la URL (GET /login/{usuario}/{contraseña})	API: Autenticar con POST y cuerpo, o con OAuth 2.0/OIDC con tokens de corta vida Infraestructura: Excluir rutas sensibles del registro de acceso y de proxies Monitoreo: Detección de credenciales en logs (DLP)	Crítico → Bajo
T03	Páginas de administración fuera del control de sesión	Aplicación: Autorización por rol (ADMIN) con deny-by-default en todas las rutas /admin Infraestructura: Publicar el módulo administrativo solo en red de gestión o VPN Aplicación: MFA para administradores Monitoreo: Alertas por acceso a rutas administrativas	Crítico → Bajo
T04	Endpoints de mantenimiento expuestos en la API (cleanDB, initializeDB, setParameter, shutdownJmsListener)	API: Separar la API operativa de la administrativa y exigir token con scope admin en esta última API: API Gateway con listas de control de acceso por ruta Infraestructura: Segmentación de red: operaciones de mantenimiento solo desde red interna Monitoreo: Registro y alerta de invocaciones de mantenimiento	Crítico → Bajo
T05	Acceso a cuentas y clientes ajenos mediante identificadores (BOLA/IDOR)	API: Autorización a nivel de objeto: comparar el ID del recurso con el sujeto del token API: Identificadores no predecibles (UUID) Monitoreo: Alerta por enumeración secuencial de IDs	Crítico → Bajo
T06	Contraseñas y SSN almacenados sin protección criptográfica	Aplicación: Hash con Argon2id o bcrypt con sal por usuario Infraestructura: Cifrado de columnas sensibles (SSN) y gestión de claves en bóveda Monitoreo: Alertas por consultas masivas sobre Customer	Alto → Bajo
T07	Cuenta sa sin contraseña y puerto HyperSQL 9001 accesible	Infraestructura: Cuenta de aplicación con privilegios mínimos y contraseña robusta en bóveda de secretos Infraestructura: Segmentación: BD accesible solo desde el servidor de aplicaciones Infraestructura: Hardening: deshabilitar la cuenta sa por defecto Monitoreo: Logging de conexiones a la BD	Alto → Medio
T08	Broker ActiveMQ en 0.0.0.0:61616 sin autenticación configurada	Infraestructura: Enlazar el broker a localhost o red interna y exigir TLS Aplicación: Autenticación y ACL por cola Aplicación: Firmar los mensajes de préstamo Monitoreo: Alertas de conexiones y mensajes anómalos	Alto → Bajo
T09	Tráfico HTTP sin TLS: credenciales y cookie de sesión interceptables	Infraestructura: TLS 1.2+ obligatorio con redirección y HSTS Aplicación: Cookie con Secure y HttpOnly Monitoreo: Monitoreo de certificados y de suites débiles	Alto → Bajo
T10	CSRF sobre transferencias y pagos	Aplicación: Token anti-CSRF por sesión en formularios de escritura Aplicación: Cookie SameSite=Lax/Strict Aplicación: Reautenticación o OTP para transferencias Monitoreo: Alerta de transferencias atípicas	Alto → Bajo
T11	Manipulación de monto o cuenta en operaciones monetarias	API: Validación de negocio en el servidor: propiedad de la cuenta, saldo y límites API: Firma o HMAC de la solicitud y control de idempotencia Infraestructura: TLS en tránsito Monitoreo: Reglas antifraude por monto y frecuencia	Alto → Bajo
T12	Fuerza bruta y credential stuffing sobre el login	Aplicación: MFA y bloqueo progresivo de cuenta API: Rate limiting por IP y por usuario en el API Gateway Aplicación: Política de contraseñas y verificación contra listas filtradas Monitoreo: SIEM con alerta de fallos de login repetidos	Alto → Bajo
T13	Alteración del umbral de aprobación de préstamos y del modo de acceso	Aplicación: Cambios de parámetros críticos con doble aprobación (cuatro ojos) Aplicación: Rangos válidos y límites máximos para el umbral Monitoreo: Alerta y auditoría de cambios de parámetros	Alto → Bajo
T14	Cabeceras CORS abiertas a cualquier origen	API: Lista blanca de orígenes permitidos API: No combinar CORS abierto con credenciales	Medio → Bajo
T15	Falta de no repudio en transacciones	Aplicación: Confirmación con OTP o firma para operaciones relevantes Monitoreo: Bitácora de auditoría con hash encadenado y sincronización de tiempo	Medio → Bajo
T16	Acciones administrativas sin identidad ni auditoría	Aplicación: Cuentas nominales con roles para administración Monitoreo: Log centralizado de acciones administrativas hacia el SIEM	Medio → Bajo
T17	Bitácoras modificables y con datos sensibles	Monitoreo: Envío en tiempo real a un SIEM con almacenamiento de solo anexo Aplicación: Enmascarar datos personales en logs	Bajo → Bajo

ID	Amenaza	Controles	Riesgo inicial → residual
T18	Denegación de servicio por API sin límites	API: Rate limiting y cuotas en el API Gateway Infraestructura: Protección anti-DDoS y autoescalado Monitoreo: Alertas de picos de tráfico	Medio → Bajo
T19	Inundación de solicitudes de préstamo sobre la cola JMS	Aplicación: Límite de solicitudes por cliente y tamaño de cola Infraestructura: Cola persistente y dead-letter queue Monitoreo: Alertas de profundidad de cola	Medio → Bajo
T20	Suplantación del proveedor de préstamos o respuesta falsa	API: TLS mutuo y firma de mensajes con validación de correlación Monitoreo: Conciliación de aprobaciones contra el proveedor	Medio → Bajo
T21	Procesamiento XML inseguro en servicios SOAP (XXE)	API: Deshabilitar DTD y entidades externas en el parser API: Validar contra XSD y limitar tamaño de mensaje Infraestructura: Egress filtering desde el servidor	Medio → Bajo
T22	Dependencias de terceros sin gestión de vulnerabilidades	Aplicación: SCA en el pipeline (OWASP Dependency-Check) y SBOM Infraestructura: Parcheo periódico de Tomcat y ActiveMQ	Medio → Bajo
T23	Cookie de sesión sin atributos de endurecimiento verificados	Aplicación: Cookie Secure/HttpOnly/SameSite, regeneración del ID al autenticar y timeout de 15 minutos Monitoreo: Detección de sesiones simultáneas desde orígenes distintos	Medio → Bajo

Nota. Elaboración propia.

8. Matriz de riesgos y remediación

Tabla 12

Plan de remediación ordenado por riesgo

ID	Riesgo	Severidad	Responsable	Acción correctiva	Fecha objetivo
T01	Inyección SQL en la actualización de clientes	Crítico	Desarrollo	Reemplazar la concatenación por parámetros con nombre y habilitar siempre SecureJdbcCustomerDao; agregar prueba unitaria de inyección	2026-11-05
T03	Páginas de administración fuera del control de sesión	Crítico	Arquitectura	Proteger las rutas administrativas con rol ADMIN y MFA, y separarlas del acceso público	2026-11-05
T04	Endpoints de mantenimiento expuestos en la API (cleanDB, initializeDB, setParameter, shutdownJmsListener)	Crítico	Arquitectura	Retirar de producción las operaciones de mantenimiento o protegerlas con OAuth 2.0 y scope administrativo detrás de un API Gateway	2026-11-05
T02	Credenciales viajan en la URL (GET /login/{usuario}/{contraseña})	Crítico	Arquitectura	Retirar el login por GET y migrar a un flujo con token (OAuth 2.0/OIDC); depurar logs existentes	2026-11-05
T05	Acceso a cuentas y clientes ajenos mediante identificadores (BOLA/IDOR)	Crítico	Desarrollo	Implementar verificación de propiedad en cada operación por ID y pruebas automatizadas de BOLA	2026-11-05
T06	Contraseñas y SSN almacenados sin protección criptográfica	Alto	Desarrollo	Migrar contraseñas a hash Argon2id y cifrar o tokenizar el SSN	2027-04-05
T07	Cuenta sa sin contraseña y puerto HyperSQL 9001 accesible	Alto	Infraestructura	Crear cuenta de servicio con mínimos privilegios, retirar sa, cerrar el puerto a la red y mover secretos a bóveda	2027-01-05
T08	Broker ActiveMQ en 0.0.0.0:61616 sin autenticación configurada	Alto	Infraestructura	Restringir el listener a la red interna, habilitar autenticación, ACL y TLS en ActiveMQ	2027-01-05
T09	Tráfico HTTP sin TLS: credenciales y cookie de sesión interceptables	Alto	Infraestructura	Terminar TLS en un balanceador o en Tomcat, activar HSTS y marcar cookies Secure/HttpOnly	2027-01-05
T10	CSRF sobre transferencias y pagos	Alto	Desarrollo	Agregar token CSRF y SameSite en todos los formularios y exigir OTP para operaciones de alto valor	2027-04-05
T11	Manipulación de monto o cuenta en operaciones monetarias	Alto	Desarrollo	Validar propiedad, saldo y límites en servidor; agregar firma de solicitud e idempotencia	2027-04-05
T12	Fuerza bruta y credential stuffing sobre el login	Alto	Desarrollo	Implementar MFA, bloqueo progresivo y rate limiting en el gateway	2027-01-05

ID	Riesgo	Severidad	Responsable	Acción correctiva	Fecha objetivo
T13	Alteración del umbral de aprobación de préstamos y del modo de acceso	Alto	Arquitectura	Imponer doble aprobación, validación de rangos y auditoría de los parámetros críticos	2027-04-05
T14	Cabeceras CORS abiertas a cualquier origen	Medio	Desarrollo	Sustituir allowAllOrigins por una lista de orígenes autorizados	2027-01-05
T15	Falta de no repudio en transacciones	Medio	Desarrollo	Registrar evidencia de consentimiento (OTP, IP, dispositivo, hora) por cada transacción	2027-04-05
T16	Acciones administrativas sin identidad ni auditoría	Medio	Arquitectura	Registrar usuario, hora y valor anterior y nuevo en cada cambio administrativo	2027-04-05
T18	Denegación de servicio por API sin límites	Medio	Infraestructura	Poner un API Gateway con cuotas y protección anti-DDoS delante de los servicios	2027-04-05
T19	Inundación de solicitudes de préstamo sobre la cola JMS	Medio	Infraestructura	Definir cuotas, cola persistente y monitoreo de profundidad	2027-04-05
T23	Cookie de sesión sin atributos de endurecimiento verificados	Medio	Desarrollo	Configurar atributos de cookie, rotación de sesión y expiración por inactividad	2027-04-05
T20	Suplantación del proveedor de préstamos o respuesta falsa	Medio	Arquitectura	Exigir mTLS y firma en la integración con proveedores	2027-10-05
T21	Procesamiento XML inseguro en servicios SOAP (XXE)	Medio	Desarrollo	Endurecer el parser XML y validar los mensajes contra el esquema	2027-10-05
T22	Dependencias de terceros sin gestión de vulnerabilidades	Medio	Desarrollo	Integrar SCA y SBOM al pipeline con política de fallo por severidad	2027-10-05
T17	Bitácoras modificables y con datos sensibles	Bajo	Infraestructura	Centralizar logs, protegerlos contra modificación y enmascarar datos sensibles	2027-04-05

Nota. Los responsables son roles genéricos y las fechas parten del 5 de octubre de 2026. Las amenazas críticas se programan primero. Elaboración propia.

9. Roadmap de mejoras

Tabla 13

Roadmap de mejoras por horizonte

Horizonte	ID	Severidad	Acción	Responsable
Corto plazo (0-3 meses)	T01	Crítico	Reemplazar la concatenación por parámetros con nombre y habilitar siempre SecureJdbcCustomerDao; agregar prueba unitaria de inyección	Desarrollo
Corto plazo (0-3 meses)	T03	Crítico	Proteger las rutas administrativas con rol ADMIN y MFA, y separarlas del acceso público	Arquitectura
Corto plazo (0-3 meses)	T04	Crítico	Retirar de producción las operaciones de mantenimiento o protegerlas con OAuth 2.0 y scope administrativo detrás de un API Gateway	Arquitectura
Corto plazo (0-3 meses)	T02	Crítico	Retirar el login por GET y migrar a un flujo con token (OAuth 2.0/OIDC); depurar logs existentes	Arquitectura
Corto plazo (0-3 meses)	T05	Crítico	Implementar verificación de propiedad en cada operación por ID y pruebas automatizadas de BOLA	Desarrollo
Corto plazo (0-3 meses)	T07	Alto	Crear cuenta de servicio con mínimos privilegios, retirar sa, cerrar el puerto a la red y mover secretos a bóveda	Infraestructura
Corto plazo (0-3 meses)	T08	Alto	Restringir el listener a la red interna, habilitar autenticación, ACL y TLS en ActiveMQ	Infraestructura
Corto plazo (0-3 meses)	T09	Alto	Terminar TLS en un balanceador o en Tomcat, activar HSTS y marcar cookies Secure/HttpOnly	Infraestructura
Corto plazo (0-3 meses)	T12	Alto	Implementar MFA, bloqueo progresivo y rate limiting en el gateway	Desarrollo
Corto plazo (0-3 meses)	T14	Medio	Sustituir allowAllOrigins por una lista de orígenes autorizados	Desarrollo
Mediano plazo (3-6 meses)	T06	Alto	Migrar contraseñas a hash Argon2id y cifrar o tokenizar el SSN	Desarrollo
Mediano plazo (3-6 meses)	T10	Alto	Agregar token CSRF y SameSite en todos los formularios y exigir OTP para operaciones de alto valor	Desarrollo
Mediano plazo (3-6 meses)	T11	Alto	Validar propiedad, saldo y límites en servidor; agregar firma de solicitud e idempotencia	Desarrollo
Mediano plazo (3-6 meses)	T13	Alto	Imponer doble aprobación, validación de rangos y auditoría de los parámetros críticos	Arquitectura

Horizonte	ID	Severidad	Acción	Responsable
Mediano plazo (3-6 meses)	T15	Medio	Registrar evidencia de consentimiento (OTP, IP, dispositivo, hora) por cada transacción	Desarrollo
Mediano plazo (3-6 meses)	T16	Medio	Registrar usuario, hora y valor anterior y nuevo en cada cambio administrativo	Arquitectura
Mediano plazo (3-6 meses)	T18	Medio	Poner un API Gateway con cuotas y protección anti-DDoS delante de los servicios	Infraestructura
Mediano plazo (3-6 meses)	T19	Medio	Definir cuotas, cola persistente y monitoreo de profundidad	Infraestructura
Mediano plazo (3-6 meses)	T23	Medio	Configurar atributos de cookie, rotación de sesión y expiración por inactividad	Desarrollo
Mediano plazo (3-6 meses)	T17	Bajo	Centralizar logs, protegerlos contra modificación y enmascarar datos sensibles	Infraestructura
Largo plazo (6-12 meses)	T20	Medio	Exigir mTLS y firma en la integración con proveedores	Arquitectura
Largo plazo (6-12 meses)	T21	Medio	Endurecer el parser XML y validar los mensajes contra el esquema	Desarrollo
Largo plazo (6-12 meses)	T22	Medio	Integrar SCA y SBOM al pipeline con política de fallo por severidad	Desarrollo

Nota. Elaboración propia.

Conclusión

La modelización de amenazas de ParaBank revela que las vulnerabilidades más severas se encuentran en decisiones de diseño y configuración, no en fallos exóticos: una consulta SQL desarrollada con concatenación, credenciales transmitidas en la URL, funciones administrativas sin autenticación, una base de datos con la cuenta de administración sin contraseña y un gestor de mensajes expuesto. Las cinco amenazas críticas se alinean con lo anticipado en una prueba de penetración sobre una aplicación ya en producción; sin embargo, en este caso, se identificaron desde el diseño.

Esta es la ventaja inherente a la implementación temprana de la seguridad. Corregir estas amenazas antes de su implementación demanda modificaciones limitadas, tales como la parametrización de consultas, la separación de la administración y la activación de autenticación y TLS. Hacerlo después implica reingeniería, adquisiciones de emergencia y riesgo para los clientes y las transacciones. La etapa subsecuente consiste en corroborar las hipótesis mediante pruebas autorizadas y colaborar con los equipos de Arquitectura y Desarrollo, manteniendo el modelo en Threat Dragon como un artefacto vivo en el ciclo de desarrollo seguro.

Referencias

- López Sajquin, M. R. (2026). *Modelado de amenazas en el diseño: DFD, STRIDE, PASTA y priorización* [Diapositivas de la semana 2]. Seguridad en Aplicaciones, Universidad Mariano Gálvez de Guatemala.
- National Institute of Standards and Technology. (2022). *Secure software development framework (SSDF) version 1.1: Recommendations for mitigating the risk of software vulnerabilities* (NIST SP 800-218). <https://doi.org/10.6028/NIST.SP.800-218>
- Open Worldwide Application Security Project. (s. f.). *OWASP Threat Dragon*. <https://owasp.org/www-project-threat-dragon/>
- Parasoft. (2026). *ParaBank* [Software]. GitHub. <https://github.com/parasoft/parabank>
- Shostack, A. (2014). *Threat modeling: Designing for security*. Wiley.